

Daniel Fraunholz, Daniel Reti, Marvin Sinnwell

Introduction

In this Lab, the very first step will be some additional exercises to become more proficient in using the Linux terminal. The second exercise is active scanning, especially network enumeration. Enumeration starts with host discovery, where hosts on the network are identified by enumerating the hosts that respond to TCP/ICMP/ARP requests. The next step is port scanning, where all the open ports on a target are enumerated. To make an assumption about possible vulnerabilities, the services and respective versions are determined by testing whether the TCP ports are open. Banner grabbing and OS fingerprinting on the host may also be helpful for finding vulnerabilities. In this lab, we will be using Kali Linux, as mentioned in the preparation guide. You also need to connect to the lab network over a VPN connection. To do this, download the VPN pack for your group in OLAT. If you are unsure how to connect to the student lab refer to the introduction slides to the lab in Olat. If you are stuck during the exercises, do not hesitate to contact Daniel Reti or Marvin Sinnwell.

As you can see in the block below there should be two tun0 interfaces listed after connecting to the VPN. The IP addresses will differ depending on your group.

```
1 $ ip route
2 default via 10.0.2.2 dev eth0 proto dhcp src 10.0.2.15 metric 100
3 10.0.2.0/24 dev eth0 proto kernel scope link src 10.0.2.15 metric 100
4 10.8.0.1 via 10.8.0.5 dev tun0
5 10.8.0.5 dev tun0 proto kernel scope link src 10.8.0.6
6 10.10.10.0/24 via 10.8.0.5 dev tun0
7 10.10.11.0/24 via 10.8.0.5 dev tun0
8 192.168.56.0/24 dev eth1 proto kernel scope link src 192.168.56.101 metric 101
```

Exercise 1: Linux basics

In this exercise we want you to familiarize yourself with Linux and the terminal. For the following commands give the output and explain what the command does. Be careful when copying. Make sure to copy correctly!

1. `find / -type f -exec grep -l "password" {} \;`

```
2 printf "line 1\nstart\nimportant line 1\nimportant line 2\nend\nline
   after\n" > file.txt && \
3 sed -n '/start/,/end/p' file.txt > extracted.txt
```

3. `awk 'BEGIN{FS=":"; OFS=":"} {if ($3 >= 1000) print $1, $3, $6}' /etc/passwd`

4. `(ls /etc; cat nonexistentfile) > stdout.log 2> stderr.log`

5. `(ls /etc; cat nonexistentfile) > combined.log 2>&1`

Exercise 2: Port scanning

a)

In this exercise, you should use the "nmap" tool. Use this tool to scan your subnet. After you have discovered the machines in your subnet, you should perform a full port scan on all machines. Since this can last quite a bit find a way to be quicker. Set different flags to see if you can discover different outcomes. In the end, you should find 24 machines.

b)

Now that you are familiar with your network, perform several port scans on one target setting different scan flags. Capture your traffic with Wireshark, which is preinstalled on Kali, and examine the difference of the scans performed. In Wireshark you can filter traffic to only see your traffic to a specific IP address. This might help you to lessen amount of packets displayed. The following command would filter all traffic that does not have the specified IP as a destination address.

```
1 ip.dst == 131.246.195.218
```

Exercise 3: Directory scan

For this exercise, you will be required to write a Python script (other languages allowed) to scan subdirectories of a machine with an HTTP service (IP address: 10.10.XX.87). We provide you with a wordlist, which you can use. You can continue to use this wordlist throughout the following exercises.

1. Identify which directories are present using an HTTP library and the given wordlist.
2. Search for files in the root path and subdirectories found in step 1. Remember that files have file extensions.

Now compare your script to common tools like gobuster, dirbuster, dirb, or similar. Get familiar with one of them and learn how to set flags, e.g., for file extensions, etc.

Exercise 4: Finding Flags

Find six flags hidden in different services on the lab machines you identified by interacting with these services. To give you a small hint to know what to look out for:

- Samba
- FTP
- SSH
- Hidden in a subdirectory
- HTML
- Login Page

IP addresses of relevant machines:

- 10.10.XX.9
- 10.10.XX.54
- 10.10.XX.65
- 10.10.XX.87

The format of the flags is `flag{somestring}`.

Hints

We want you to try first and ask us when you feel stuck (Daniel Reti or Marvin Sinnwell). Tell me what you have tried so far, and I will help you with further hints.

Report

Write a brief report including your solutions. Then, submit the report via Olat. You can find a $\text{\LaTeX}$ template on OLAT.